



# LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



## Daily Priority: Microsoft SharePoint CVE-2026-65660 Code Injection

CVE / Vulnerability Threat Intelligence Report

|                       |                                                |
|-----------------------|------------------------------------------------|
| <b>Classification</b> | TLP:CLEAR                                      |
| <b>Published</b>      | 2026-09-28                                     |
| <b>Version</b>        | 1.0                                            |
| <b>Author</b>         | Lost Boys Cyber                                |
| <b>Report Type</b>    | CVE / Vulnerability Threat Intelligence Report |

TLP:CLEAR | Lost Boys Cyber | Daily Priority: Microsoft SharePoint CVE-2026-65660 Code Injection - CVE / Vulnerability Threat Intelligence Report

Published: 2026-09-28 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

## Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
  - 9.1. Detection Logic Summary
  - 9.2. Sigma / Detection Content
  - 9.3. Hunt Query
10. Threat Hunting
  - 10.1. Hunt Hypothesis
  - 10.2. Hunt Query
  - 10.3. Analyst Triage Notes
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

# Daily Priority: Microsoft SharePoint CVE-2026-65660 Code Injection

## 1. Executive Summary

CVE-2026-65660 is prioritized for today because public reporting and CISA KEV context indicate defenders should treat affected Microsoft SharePoint Server deployments as time-sensitive exposure. The operational risk is highest where the product is internet reachable, integrated with identity/session flows, or trusted by downstream business applications.

Lost Boys Cyber assesses that patch validation, exposure reduction, and focused hunt coverage are more important than broad vulnerability counting for this item. The immediate goal is to identify externally reachable instances, verify fixed versions or vendor mitigations, and hunt for authentication, web, or process anomalies that align with exploitation attempts.

## 2. Vulnerability Metadata

| Field                            | Value                                                                                                                                   |
|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|
| CVE                              | CVE-2026-65660                                                                                                                          |
| Product / Component              | Microsoft SharePoint Server                                                                                                             |
| Weakness                         | Code injection / authenticated remote code execution as reported                                                                        |
| Severity                         | High / CVSS reported around 8.8 in secondary coverage                                                                                   |
| Affected Versions                | See vendor advisory and asset-specific package inventory                                                                                |
| Fixed Versions                   | See vendor advisory; verify hotfix level rather than relying on product family alone                                                    |
| Disclosure / Prioritization Date | 2026-09-28 daily coverage; source reporting spans the last 24-72 hours where available                                                  |
| Exploitation Status              | Reported as actively exploited or KEV-relevant in current source set; validate against CISA/vendor data before emergency change windows |

## 3. Source Review & Confidence

| Source                          | Contribution                                                                  | Confidence |
|---------------------------------|-------------------------------------------------------------------------------|------------|
| CISA KEV alert                  | CISA alert says CVE-2026-65660 was added to KEV based on active exploitation. | High       |
| SecurityWeek                    | Reports exploitation and September 28 federal patch deadline.                 | Medium     |
| Microsoft Security Update Guide | Canonical vendor source for SharePoint fixed versions and mitigations.        | Medium     |

Confidence is High for prioritization and remediation urgency because at least one authoritative or high-signal source ties the issue to active exploitation or emergency patching. Confidence is Medium for exploit mechanics where secondary reporting diverges; defenders should rely on vendor remediation text for exact version scope.

## 4. Vulnerability Details

The vulnerability affects Microsoft SharePoint Server. The reported weakness is Code injection / authenticated remote code execution as reported. In practical terms, exploitation risk concentrates around exposed application endpoints, trusted

administration planes, session/token validation paths, and integrations where compromise would grant access to sensitive data or management workflows.

## 5. Attack Scenarios

- An unauthenticated or low-privileged attacker targets an exposed service and abuses the vulnerable code path to obtain elevated access or execute attacker-controlled actions.
- A compromised user session or forged request is used to pivot into administrative workflows that are normally trusted by downstream systems.
- An attacker chains successful exploitation with credential theft, web shell deployment, data export, or persistence in adjacent identity/application layers.

## 6. Threat Landscape & Exploitation Status

Current public reporting places this issue in the defender-priority tier because exploitation pressure is reported before all organizations have completed patch validation. Organizations should not wait for exploit code to be published; exposure management and telemetry review should begin immediately.

## 7. Affected Products and Exposure

| Exposure Pattern                            | Why It Matters                                                                                               |
|---------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Internet-facing Microsoft SharePoint Server | Increases probability of opportunistic scanning, exploitation attempts, and credential/session abuse         |
| High-trust internal deployment              | Compromise may grant access to source data, APIs, or business workflows even without broad internet exposure |
| Third-party hosted or managed instance      | Requires provider confirmation of patch level, logs, and incident indicators                                 |
| Patched and segmented instance              | Lower risk, but hunt review is still recommended for pre-patch exposure windows                              |

## 8. Mitigation and Workarounds

| Priority | Owner                    | Action                                                                                                       |
|----------|--------------------------|--------------------------------------------------------------------------------------------------------------|
| Critical | Vulnerability Management | Identify all Microsoft SharePoint Server instances and verify vendor-fixed versions or compensating controls |
| Critical | Network / Platform       | Restrict external access to management and application endpoints until patch state is confirmed              |
| High     | SOC                      | Run the detection and hunt queries below for the exposure window plus 14 days                                |
| High     | Identity / App Owners    | Rotate affected tokens, invalidate suspicious sessions, and review privileged account activity               |

## 9. Detection Engineering

### 9.1. Detection Logic Summary

| Signal | Telemetry Source | Analytic Goal |
|--------|------------------|---------------|
|--------|------------------|---------------|

|                                                                                                                          |                                           |                                                                                   |
|--------------------------------------------------------------------------------------------------------------------------|-------------------------------------------|-----------------------------------------------------------------------------------|
| New external access to management or sector-critical SaaS surfaces related to CVE-2026-65660 Microsoft SharePoint Server | Proxy, WAF, EDR network telemetry         | Identify exploitation, credential replay, or staged operator access before impact |
| Administrative token, account, or session anomalies near affected systems                                                | Identity provider, application audit, EDR | Find post-exploitation privilege use and lateral movement                         |
| Unusual archive, export, or bulk-download behavior after suspicious access                                               | EDR file telemetry, DLP, SaaS audit       | Surface data staging or operational disruption precursors                         |

## 9.2. Sigma / Detection Content

```

title: Lost Boys Cyber - CVE-2026-65660 Microsoft SharePoint Server Suspicious Access Pattern
status: experimental
description: Flags suspicious user-agent or URI patterns around the daily-priority topic; tune keywords to local asset names and vendor paths.
logsource:
  category: proxy
  product: web_proxy
detection:
  selection_keywords:
    request_uri|contains:
      - "sharepoint"
      - "cve-2026-65660"
      - "/_layouts/"
      - "powershell"
  selection_status:
    status_code:
      - 200
      - 401
      - 403
      - 500
  condition: selection_keywords and selection_status
fields:
  - src_ip
  - user
  - request_uri
  - user_agent
falsepositives:
  - vulnerability scanners
  - legitimate vendor administration
level: medium

```

## 9.3. Hunt Query

```

// Lost Boys Cyber daily hunt: CVE-2026-65660 Microsoft SharePoint Server
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where tolower(RemoteUrl) has "sharepoint" or tolower(RemoteUrl) has "cve-2026-65660" or
tolower(RemoteUrl) has "/_layouts/"
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Events=count() by DeviceName,
InitiatingProcessAccountName, RemoteUrl, RemoteIP
| order by Events desc

```

# 10. Threat Hunting

## 10.1. Hunt Hypothesis

Operators should test whether exposed systems, sector-specific workflows, or shared-service dependencies show signs of access attempts tied to CVE-2026-65660 Microsoft SharePoint Server. A hit is not automatically malicious; triage should compare source ASN, authentication context, user role, and timing against maintenance windows.

## 10.2. Hunt Query

|                                                                                                                                                                                                                                                                                                                                                                                                                              |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DeviceProcessEvents<br>  where Timestamp > ago(14d)<br>  where tolower(ProcessCommandLine) has "sharepoint" or tolower(ProcessCommandLine) has "cve-2026-65660" or tolower(ProcessCommandLine) has "/_layouts/" or tolower(ProcessCommandLine) has "powershell"<br>  project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine, InitiatingProcessParentFileName<br>  order by Timestamp desc |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## 10.3. Analyst Triage Notes

| Step     | Question                                                           | Evidence to Preserve                                         |
|----------|--------------------------------------------------------------------|--------------------------------------------------------------|
| Scope    | Which hosts, tenants, or applications saw matching activity?       | Raw event IDs, URLs, source IPs, affected accounts           |
| Validate | Was the activity scheduled, scanner-driven, or user-initiated?     | Change tickets, scanner allowlists, admin approvals          |
| Contain  | Is there evidence of credential/session misuse or tool deployment? | Token revocation logs, EDR timeline, application audit trail |

## 11. MITRE ATT&CK Mapping

| Technique | Name                              | Evidence / Rationale                                                                          |
|-----------|-----------------------------------|-----------------------------------------------------------------------------------------------|
| T1190     | Exploit Public-Facing Application | Vulnerability affects remotely reachable application surfaces when exposed                    |
| T1133     | External Remote Services          | Attackers may use valid sessions or exposed management paths after initial access             |
| T1059     | Command and Scripting Interpreter | If exploitation enables command execution, attacker tooling may spawn interpreters or scripts |
| T1078     | Valid Accounts                    | Session/token abuse can resemble legitimate application account activity                      |

## 12. Validation / Lab Testing

No exploit reproduction was performed in this automated daily run. Validation completed: source corroboration, affected-surface analysis, detection/hunt drafting, and PDF rendering QA. Operators should test detections against local telemetry and vendor-safe validation steps only.

## 13. Recommended Actions Summary

| Priority | Owner     | Action                                                                           |
|----------|-----------|----------------------------------------------------------------------------------|
| Critical | App Owner | Patch or isolate affected systems today                                          |
| High     | SOC       | Hunt for suspicious access and post-exploitation activity using the embedded KQL |
| High     | IR Lead   | Preserve logs before patch/restart cycles<br>remove short-retention evidence     |

|        |     |                                                                               |
|--------|-----|-------------------------------------------------------------------------------|
| Medium | GRC | Track vendor and CISA updates for deadline changes or broadened product scope |
|--------|-----|-------------------------------------------------------------------------------|

## 14. References

- [1] CISA KEV alert — <https://www.cisa.gov/news-events/alerts/2026/09/25/cisa-adds-two-known-exploited-vulnerabilities-catalog> — CISA alert says CVE-2026-65660 was added to KEV based on active exploitation.
- [2] SecurityWeek — <https://www.securityweek.com/microsoft-sharepoint-flaw-cve-2026-65660-now-exploited-in-attacks/> — Reports exploitation and September 28 federal patch deadline.
- [3] Microsoft Security Update Guide — <https://msrc.microsoft.com/update-guide/> — Canonical vendor source for SharePoint fixed versions and mitigations.